COTEJO

Programa de auditoría con verificación automatizada de controles

Sistema auditado: **Rastro**

Sergio Montoya · Nicolás Torres · Oscar Rincón
Auditoría de Sistemas (ISD39) · Grupo 30112



1 · Portada · Nicolás · ≈ 15 s

Nicolás: Buenos días, profesor. Somos Sergio Montoya, Nicolás Torres y Oscar Rincón, del grupo 30112. Presentamos Cotejo, un programa que audita de forma automatizada los controles de Rastro, en los siete bloques pedidos.

INDICACIÓN Cinco segundos. Mirar al jurado, no a la pantalla. A la derecha van pasando solas las cuatro pantallas de Cotejo: revisión, catálogo, repetición y un papel de trabajo. No hay que esperarlas ni comentarlas.

BLOQUE 1 · PRESENTACIÓN DEL SISTEMA

El problema y el sistema auditado

> **Un control declarado no es un control verificado.**

Sistema auditado. Rastro, trazabilidad de envíos en AWS `us-east-1`: ocho funciones, tres tablas, almacén cifrado y registro de actividad. **Lo construimos nosotros**, en Cloud Computing.

Lo comprobamos antes de construir nada:

La configuración dice	El sistema hace
Autoriza a cualquier principal	Rechaza **toda** invocación

Un auditor que solo lee configuraciones habría reportado un hallazgo falso.



2 · El problema y el sistema auditado · Nicolás · ≈ 25 s

Nicolás: Auditamos Rastro, desplegado en AWS, y lo decimos de entrada: lo construimos nosotros. La idea de Cotejo es que un control declarado no es un control verificado. Una función cuya política autoriza a cualquiera rechazaba toda invocación: quien solo leyera la configuración habría reportado un hallazgo falso. Por eso Cotejo no solo lee: usa el sistema.

INDICACIÓN Decir primero que es nuestro sistema quita la objeción antes de que el jurado la haga. A la derecha se ve el panel de Rastro y, a los cinco segundos, el catálogo de Cotejo, que es donde el criterio está escrito antes de probar.

SI PREGUNTAN La organización es una mensajería urbana pequeña de Bogotá que comparte infraestructura con otras empresas; cuenta `484948252891`. La prueba previa es evidencia recuperable: el comando y la petición se repiten y dan el mismo resultado (apartado 3.1 del documento). La falta de independencia se trata con rotación interna y se declara como limitación. ¿Cotejo es una página web? No: es un programa que corre en el equipo del auditor contra el sistema desplegado; la vía principal es `python -m cotejo ejecutar`. Las pantallas son su interfaz de consulta para el rol auditor (apartado 7.2), que lee el mismo catálogo que la consola. No se publica a propósito: los papeles de trabajo enumeran las debilidades del sistema auditado y publicarlos ampliaría la superficie sin necesidad.

BLOQUE 2 · PLANIFICACIÓN

Objetivo, alcance y plan

Objetivo. Verificar de forma automatizada y reproducible los controles de un sistema desplegado, con papeles de trabajo trazables a un marco.

Alcance: diez controles sobre infraestructura, aplicación, bitácora y secretos.
Fuera: proceso de desarrollo, código fuente, intrusión y otros sistemas.

Fase	Semanas	Responsable
Planeación y catálogo	1–3	Oscar Rincón
Diseño del programa	4–5	Sergio Montoya
Construcción	6–9	Nicolás Torres
Ejecución y comunicación	10–12	Oscar Rincón

Independencia interna: quien construyó un componente de Rastro no ejecuta ni evalúa sus pruebas.
Sin costo adicional. No logrado: retención inmutable del almacén de papeles.

3 · Objetivo, alcance y plan · Nicolás · ≈ 25 s

Nicolás: El objetivo fue verificar de forma automatizada y reproducible los controles de un sistema desplegado. El alcance son diez controles. Fueron doce semanas en cuatro fases, con una regla: quien construyó un componente de Rastro no ejecuta ni evalúa sus pruebas. No hubo costo adicional, y declaramos lo no logrado: la retención inmutable del almacén.

SI PREGUNTAN Los cuatro objetivos específicos siguen el orden de una auditoría y se cumplieron: definir el universo auditable y la matriz de controles, diseñar el programa con su criterio, construir el ejecutor y el almacén de papeles, y ejecutar para emitir el informe. Diez controles dan once resultados porque el de secretos se parte en tres: árbol actual, historial y vigencia. Actividades: catálogo derivado de COBIT, ITAF, ISO 27001, CIS y OWASP; programa de unas 3.400 líneas con tres familias de prueba; interfaz solo para el rol auditor; dos ejecuciones contra el sistema desplegado. Quedó fuera también la vigilancia continua desatendida.

BLOQUE 3 · METODOLOGÍA

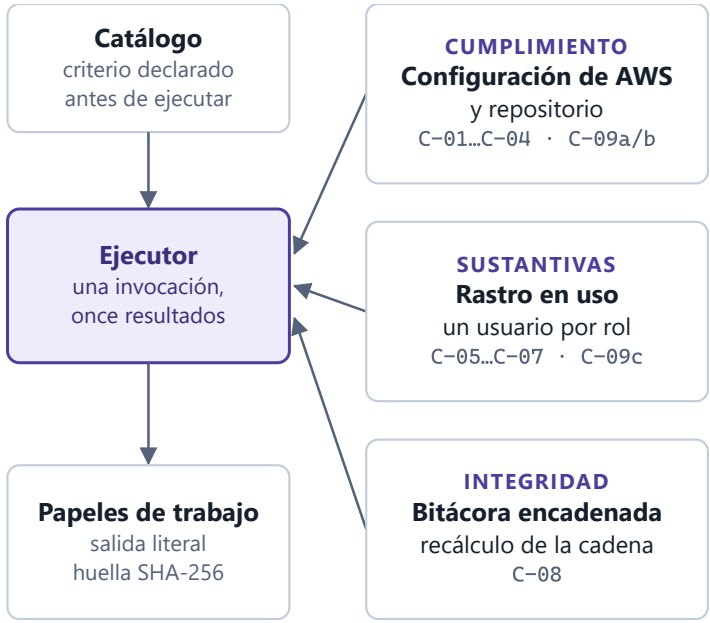
Metodología y técnicas

Secuencia **ITAF** (ISACA): planeación → programa → ejecución → comunicación.

El criterio se declara antes de ejecutar la prueba.

BIEN	Se probó y cumplió el criterio
MAL	Se probó y no cumplió: hallazgo
SIN REVISAR	No se pudo probar: **no aprobado**

Sin entrevistas: el objeto es un sistema, no un proceso humano.



4 · Metodología y técnicas · Oscar · ≈ 30 s

Oscar: Gracias, Nicolás. Seguimos la secuencia de ITAF, con una regla: el criterio se declara antes de ejecutar, para que no se acomode al resultado. El ejecutor inspecciona la configuración, usa el sistema con un usuario por rol y recalcula la cadena de la bitácora. Cada prueba termina en tres conclusiones, no dos: lo que no se pudo probar no cuenta como aprobado.

INDICACIÓN Señalar en la figura las tres fuentes mientras se nombran.

SI PREGUNTAN ¿Por qué ITAF? Es el marco de prácticas profesionales de auditoría de sistemas de ISACA y define qué es evidencia suficiente y confiable. Técnicas: revisión documental de marcos para el catálogo, inspección de configuración para las pruebas de cumplimiento, reejecución de operaciones para las sustantivas, recálculo criptográfico para la integridad y análisis del repositorio para los secretos. Sin entrevistas ni listas de verificación: preguntarle al responsable daría justo la respuesta que el proyecto busca evitar. El catálogo tiene fecha anterior a la primera ejecución.

BLOQUE 4 · RIESGOS Y CONTROLES

Amenazas y controles

Amenaza	Prob.	Impacto	Control
Acceso a datos de otra organización	Media	Muy alto	Clave de partición por organización · C-06
Alteración del histórico	Baja	Muy alto	Bitácora encadenada · C-08
Operación por rol no autorizado	Media	Alto	Autorización en capa común · C-05
Exposición de secretos	Media	Muy alto	C-09a, C-09b, C-09c
Evidencias legibles por terceros	Baja	Alto	Cifrado y bloqueo público · C-02, C-03

Activo que suele olvidarse: los papeles de trabajo, porque enumeran las debilidades.
Faltan, porque el entorno lo impide: rol por función, credenciales de solo lectura para el auditor y ancla de integridad externa.

5 · Amenazas y controles · Oscar · ≈ 25 s

Oscar: Cada amenaza tiene su probabilidad, su impacto y un control del catálogo. Tres son de impacto muy alto, y la exposición de secretos se materializó. Un activo que suele olvidarse son los papeles de trabajo, que enumeran las debilidades: por eso no están en el repositorio público. Y faltan tres controles que el entorno impide construir.

SI PREGUNTAN Los demás activos son los datos de envíos y destinatarios, las evidencias de entrega, la bitácora, la llave de cifrado y el secreto de firma. Los papeles se entregan directamente al evaluador. Otra amenaza: enumeración de envíos, probabilidad media e impacto medio, controlada con identificadores aleatorios. Controles que existen y funcionan: registro de actividad con validación de integridad, cifrado con llave propia y rotación, bloqueo público, versionado, autorización por rol, aislamiento, máquina de estados y bitácora encadenada.

BLOQUE 4 · RIESGOS Y CONTROLES

Roles y segregación de funciones

Rol	Puede	No puede
Administrador	Todo: envíos, catálogos, cuentas y roles	**Leer la bitácora**
Coordinador	Despachar, reanudar incidencias, editar catálogos	Administrar cuentas
Despachador	Crear y asignar envíos, registrar eventos	Reanudar incidencias
Conductor	Ver **sus** envíos, marcar avance, cargar evidencia	Crear o asignar envíos
Auditor	Consultar y **leer la bitácora**	Cualquier escritura

C-05 comprueba una celda: un conductor que intenta crear un envío recibe 403 y queda registrado.
Fuera de la aplicación, las funciones y el propio auditor usan un rol amplio: H-PERM-01 y H-PERM-02.

6 · Roles y segregación de funciones · Oscar · ≈ 25 s

Oscar: Para la auditoría importa la segregación: ningún rol combina operar con leer la bitácora. Y seamos precisos: C-05 comprueba una celda de esta matriz, un conductor que intenta crear un envío y recibe 403. Dentro de la aplicación la matriz se cumple; fuera, las funciones y el propio auditor usan un rol amplio. Sergio sigue con la normativa.

INDICACIÓN Decirlo así evita que parezca que la auditoría recorrió toda la matriz.

SI PREGUNTAN La matriz se tomó del código del sistema auditado. De 19 operaciones: Administrador 17, Coordinador 12, Despachador 9, Conductor 6 y Auditor 8. Reglas no configurables: el rol de administrador no se edita, ninguna cuenta suma roles que juntos operen y auditen, nadie concede un permiso que no tiene y sin permiso de asignar solo se actúa sobre envíos propios. Las demás celdas las cubren las pruebas del propio Rastro (`tests/e2e/test_roles.py`), que no son pruebas de auditoría. Los usuarios de prueba de Cotejo son uno por rol y organización, con credenciales por variable de entorno sin versionar, y la interfaz de Cotejo solo admite al rol auditor.

BLOQUE 5 · NORMATIVAS

Normativas y cumplimiento

Marco	Qué aporta	Control
COBIT 2019, DSS05 y DSS06	Seguridad y control de procesos	C-05, C-06, C-07
ITAF	Evidencia suficiente y confiable	Estructura del informe
ISO/IEC 27001:2022	Criptografía, copias, autenticación	C-02, C-04, C-09
CIS AWS Benchmark	Configuración segura de la cuenta	C-01, C-03
OWASP Top 10:2021 A01	Control de acceso deficiente	C-05, C-06
NIST SP 800-92 y 800-57	Registros y compromiso de llaves	C-01, C-09c

11	10	1	0
resultados	conformes	desviado	sin ejecutar

7 · Normativas y cumplimiento · Sergio · ≈ 20 s

Sergio: Gracias, Oscar. Cada control sale de un marco: COBIT, ITAF, ISO 27001, CIS, OWASP y NIST; así, un control ausente es una decisión de alcance y no un olvido. En la ejecución de referencia hubo once resultados: diez conformes, uno desviado y ninguno sin ejecutar.

INDICACIÓN No leer la tabla: nombrar los marcos y llegar a las cifras.

SI PREGUNTAN Cumplen el registro con validación de integridad, el cifrado con rotación, el bloqueo público, el versionado, la autorización por rol, el aislamiento, las transiciones válidas, la bitácora, el árbol del repositorio limpio y la vigencia de los secretos hallados. Incumple: un secreto sigue en el historial de commits. La ejecución de referencia es la del 26/09/2026.

BLOQUE 6 · HALLAZGOS Y EVIDENCIAS

Hallazgos

H-01 · Condición	Un secreto de firma permanece en el historial, fuera del árbol actual
Criterio	ISO/IEC 27001 A.5.17 y A.8.4 · CWE-798
Causa	Se versionó; retirar el archivo no lo saca del historial
Riesgo	Severidad media: el secreto ya fue invalidado
Recomendación	Reescribir el historial

H-PERM-01 · Mínimo privilegio — alta. Las ocho funciones comparten un rol amplio.
H-PERM-02 · Privilegios del auditor — media. El programa puede escribir sobre lo que audita.

Los hallazgos en la pantalla de revisión



8 · Hallazgos · Sergio · ≈ 25 s

Sergio: H-01 sigue el formato de la rúbrica: un secreto de firma sigue en el historial; incumple ISO 27001 y CWE-798; se versionó, y borrarlo no lo saca del historial. Severidad media, porque ya está invalidado: hay que reescribir el historial. Los otros dos son permanentes: mínimo privilegio, alta, y un auditor que puede escribir sobre lo que audita, media.

SI PREGUNTAN Evidencia de H-01: papel `C-09b.json`, huella `f56b8e66…`. Reescribir el historial no sustituye a la rotación, que ya se ejecutó. Los permanentes no se automatizan a propósito: una prueba que siempre da el mismo resultado no aporta información; se declaran en cada informe. El laboratorio no permite crear roles. La pantalla es de una ejecución en la pila local, con datos sintéticos: los controles que necesitan la cuenta de AWS quedan SIN REVISAR, que es justamente la tercera conclusión; la ejecución de referencia es la del 26/09/2026 contra el sistema desplegado.

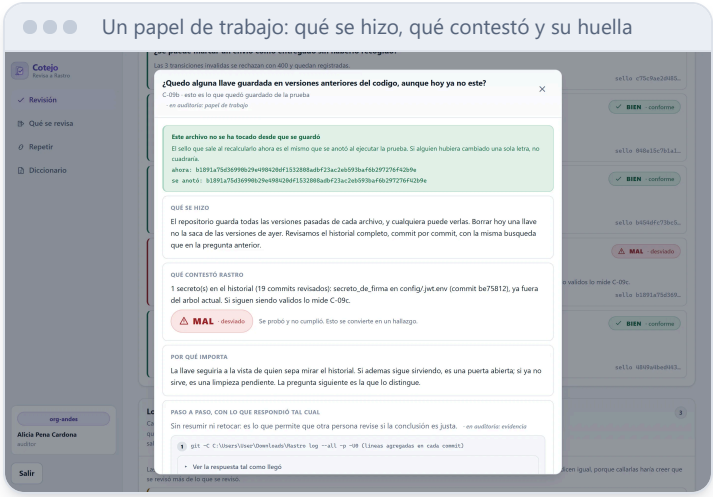
BLOQUE 6 · HALLAZGOS Y EVIDENCIAS

También nos auditamos

El incidente. Publicamos un secreto de firma durante **27 minutos**. Lo vimos al revisar el despliegue, no con Cotejo: **ningún control del catálogo cubría los secretos**. Añadimos C-09.

El error de método. El control de cifrado dijo MAL con el almacén vacío. Lo correcto era SIN REVISAR.

Cada papel de trabajo conserva: procedimiento · salida literal · marca de tiempo · identidad · huella SHA-256.



9 · También nos auditamos · Sergio · ≈ 30 s

Sergio: Y hablamos de nuestros errores. Publicamos un secreto durante 27 minutos y lo vimos nosotros, no Cotejo: el catálogo no cubría secretos, y lo cerramos con C-09. Y el control de cifrado dijo MAL con el almacén vacío, cuando era SIN REVISAR. Por eso cada papel conserva procedimiento, salida, hora, identidad y huella: sin eso, un resultado es solo una afirmación.

INDICACIÓN Decirla despacio: es la diapositiva más importante. Al llegar a «cada papel conserva», señalar la pantalla: arriba, las dos huellas que coinciden; debajo, qué se hizo y qué contestó Rastro. `z` la amplía.

SI PREGUNTAN ¿Qué aportó C-09? Separa lo que sigue expuesto, el historial, de lo que ya no abre nada: C-09c firma un token con el secreto hallado y comprueba que el sistema lo rechaza. En la ejecución de referencia encontró el secreto que sigue en el historial. El error fue del criterio, no de la ejecución. La huella SHA-256 permite comprobar que el papel no cambió después de escribirse; no permite verificarlo sin tenerlo.

BLOQUE 7 · CONCLUSIONES Y MEJORAS

Conclusiones y mejoras

- Once controles evaluados, **ninguno sin ejecutar**; diez conformes, uno desviado
- En dos ejecuciones, diez controles **se repiten igual**
- 34 pruebas del propio programa, dentro de una suite de 234 en verde

Acción inmediata	Responsable	Tiempo
Partir el control de cifrado en dos	Oscar Rincón	4 horas
Validación en doble sentido de cumplimiento	Nicolás Torres	1 semana

Limitaciones: auditamos lo que construimos · solo se verifica el catálogo · el ejecutor puede escribir sobre lo que audita.

10 · Conclusiones y mejoras · Nicolás · ≈ 30 s

Nicolás: En conclusión: once controles evaluados y ninguno sin ejecutar, con resultados que se repiten. Dos acciones no dependen del entorno y las podemos hacer ya. Y declaramos los límites: auditamos lo que construimos y el ejecutor puede escribir sobre lo que audita. Dos reglas sostuvieron todo: declarar el criterio antes de probar y no aprobar lo que no se pudo comprobar. Muchas gracias.

INDICACIÓN Después de «gracias», callarse.

SI PREGUNTAN Entre las dos ejecuciones, C-02 cambió solo por la única diferencia introducida a propósito: cargar una evidencia. Tres hallazgos: uno corregible y dos permanentes por el entorno. Acciones que dependen del entorno: credenciales de solo lectura y cuenta separada (Nicolás, una semana), firma asimétrica y anclaje externo (Sergio, tres semanas), retención inmutable (Sergio, cuatro horas); y validar el informe con auditores externos (Oscar, dos semanas). El criterio de cierre está en el apartado 15.2 del documento. La rotación interna y el programa determinista no equivalen a una revisión externa. Repositorio: `github.com/Serann10255/Rastro`.